

Fundamentals of Information Systems Security

Chapter 9 Quiz: Auditing, Monitoring, and Testing

Name: _____

Date: _____

Total Points: 100

Time Allowed: 30 Minutes

Instructions

- This quiz contains **20 questions** covering Chapter 9
- Answer all questions to the best of your ability
- Multiple choice questions have only one correct answer
- True/False questions should be marked T or F
- Short answer questions require concise, accurate responses

Section A: Multiple Choice (40 points)

1. (4 points) What is a security audit?
 - A. A systematic evaluation of a computing environment against security goals
 - B. A type of firewall
 - C. An encryption algorithm
 - D. A vulnerability scanner
2. (4 points) What are the four steps of the security review cycle?
 - A. Plan, Do, Check, Act
 - B. Monitor, Audit, Improve, Secure
 - C. Identify, Assess, Mitigate, Monitor
 - D. Prepare, Detect, Respond, Recover
3. (4 points) What is a baseline in security auditing?
 - A. A documented minimum level of security configuration
 - B. The highest level of security
 - C. A type of malware
 - D. A network protocol
4. (4 points) What is the difference between an IDS and an IPS?
 - A. IDS is passive (detects); IPS is active (prevents)
 - B. IDS is active; IPS is passive
 - C. They are the same thing

- D. IDS is for networks; IPS is for hosts
5. (4 points) Which type of detection compares traffic against known attack patterns?
- A. Anomaly-based detection
 - B. Signature-based detection
 - C. Behavioral detection
 - D. Statistical detection
6. (4 points) What is a false positive in monitoring?
- A. An alert triggered for benign activity
 - B. A real attack that was missed
 - C. A configuration error
 - D. A successful attack
7. (4 points) What is a false negative in monitoring?
- A. An alert triggered for benign activity
 - B. A real attack that was missed
 - C. A configuration error
 - D. A false alarm
8. (4 points) What does SIEM stand for?
- A. Security Information and Event Management
 - B. Security Infrastructure and Enterprise Management
 - C. System Information and Event Monitoring
 - D. Security Intelligence and Event Management
9. (4 points) What is system hardening?
- A. Changing default configurations to make a system more secure
 - B. Adding more features to a system
 - C. Installing more software
 - D. Removing all security features
10. (4 points) What is the difference between vulnerability testing and penetration testing?
- A. Vulnerability testing identifies weaknesses; penetration testing exploits them
 - B. Penetration testing identifies weaknesses; vulnerability testing exploits them
 - C. They are the same thing
 - D. Vulnerability testing is for networks; penetration testing is for applications

Section B: True/False (20 points)

11. (2 points) Audits are always announced to ensure accurate results.
- A. True
 - B. False
12. (2 points) COBIT is a framework for IT governance.

- A. True
 - B. False
13. (2 points) SOC reports are used to report on controls at service organizations.
- A. True
 - B. False
14. (2 points) Log files are not important for accountability.
- A. True
 - B. False
15. (2 points) System hardening is only necessary for servers, not workstations.
- A. True
 - B. False
16. (2 points) A DMZ is a buffer zone between trusted and untrusted networks.
- A. True
 - B. False
17. (2 points) Black-box testing requires full knowledge of the system.
- A. True
 - B. False
18. (2 points) White-box testing provides the deepest analysis of a system.
- A. True
 - B. False
19. (2 points) Continuous monitoring is essential for maintaining security posture.
- A. True
 - B. False
20. (2 points) Penetration testing should never be performed on production systems.
- A. True
 - B. False

Section C: Short Answer (40 points)

21. (10 points) Explain the four permission levels (Promiscuous, Permissive, Prudent, Paranoid). When would each be appropriate?

22. (10 points) Describe the difference between signature-based detection and anomaly-based detection in IDS/IPS systems.
23. (10 points) What are the benefits of using SIEM and SOAR in a Security Operations Center (SOC)?
24. (10 points) Explain the difference between black-box, white-box, and gray-box testing. When would you use each?

End of Quiz